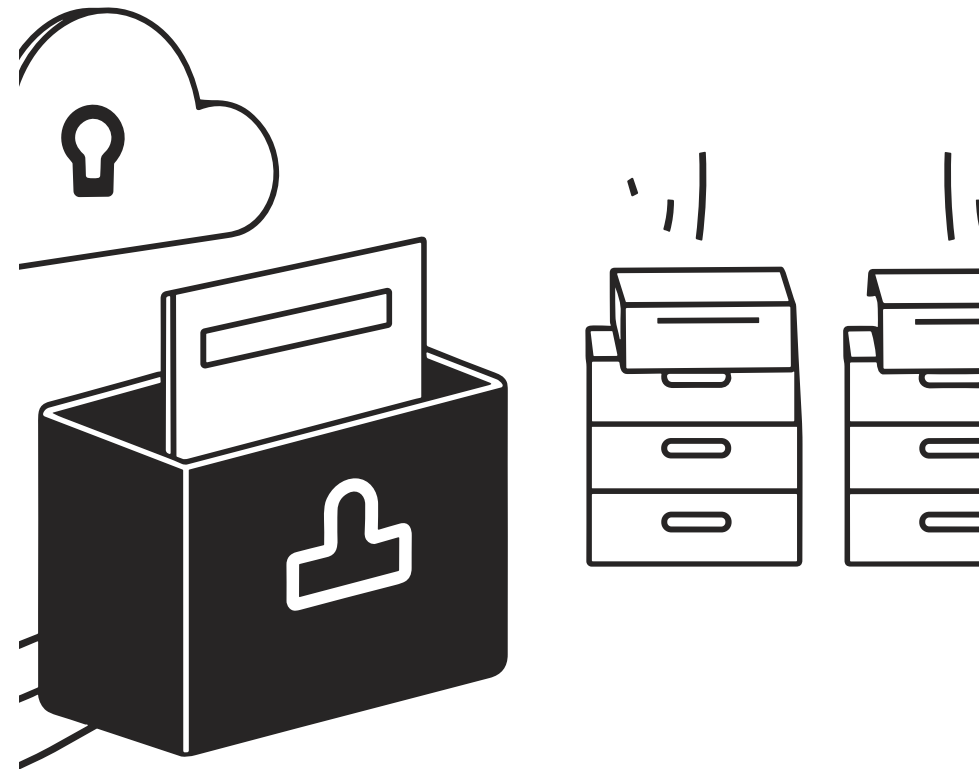


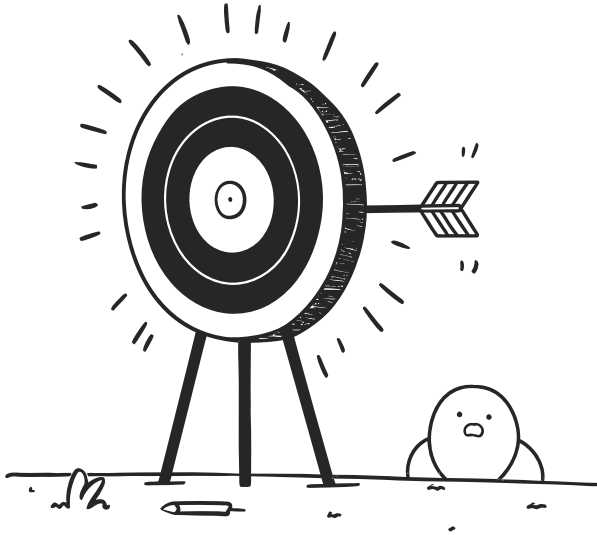
R4M3 — Protecció de l'API

Microrepte de l'RA7 · Cicle Formatiu de Desenvolupament d'Aplicacions Web

RA7.E · RA7.F



Objectiu del microrepte



Què has de fer?

Protegir el teu servei d'API amb un **mecanisme de control d'accés adequat** al nivell del curs, i demostrar que funciona en els dos escenaris possibles:

✓ Cas autoritzat

L'API respon correctament quan la credencial és vàlida.

✗ Cas denegat

L'API rebutja la petició quan la credencial és incorrecta o absent.

Punts clau a entendre

No és repetir el login de R2

El login autentica un usuari a una aplicació web. Ací es tracta de **controlar l'accés a un endpoint d'API**, amb un mecanisme específic per a serveis REST.

El cas denegat és igual d'important

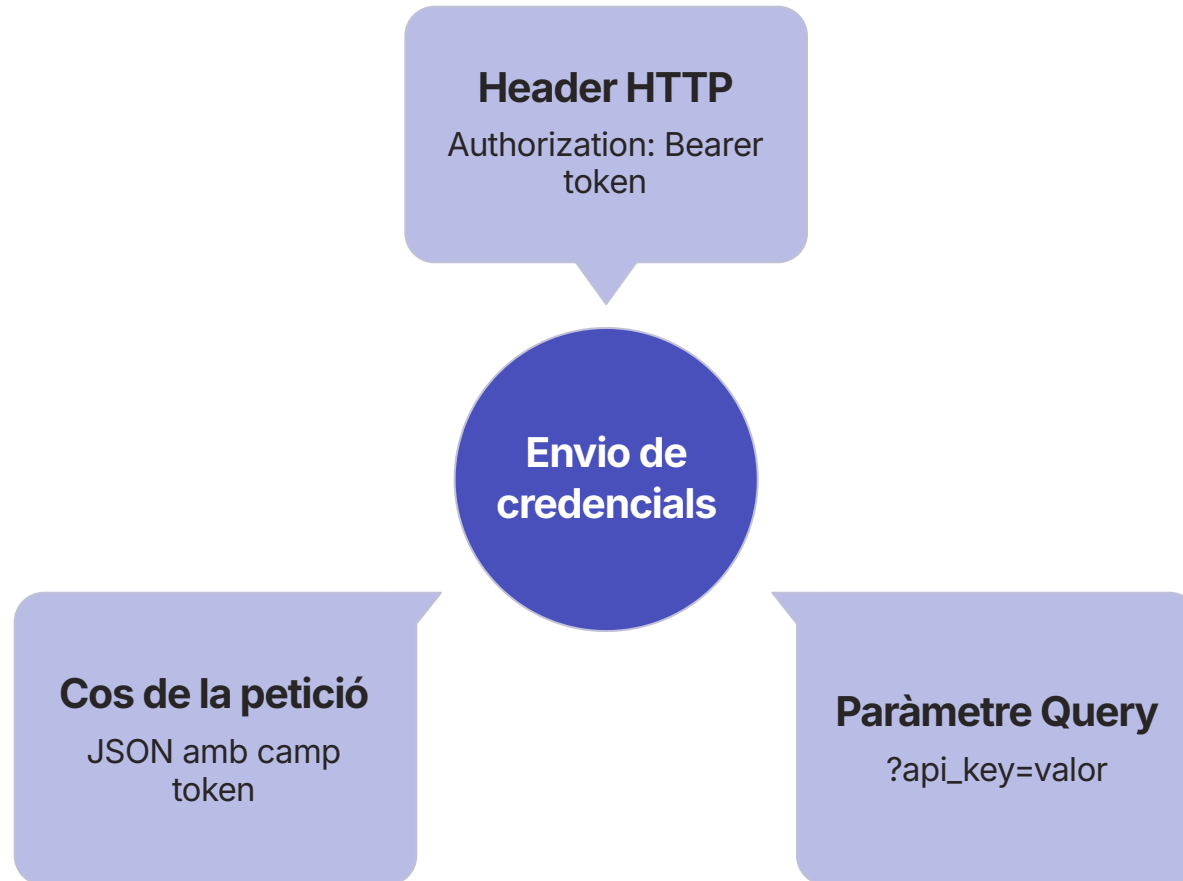
Demostrar que l'API **rebutja accessos no autoritzats** és tan rellevant com el cas correcte. Tots dos formen l'evidència completa.

La resposta d'error ha de ser coherent

Un error ben format (codi HTTP adequat + missatge clar) mostra que el disseny de l'API és professional i consistent.



Com s'envia la credencial



Cal **documentar clarament** quin mecanisme heu triat i com el client ha d'incloure la credencial en cada petició. Sense documentació, l'evidència és incompleta.

Evidències que has de presentar

1

Mecanisme de control d'accés

Codi que implementa la verificació de la credencial a l'API.

2

Cas autoritzat

Petició amb credencial vàlida → resposta correcta de l'API.

3

Cas denegat

Petició sense credencial o incorrecta → l'API rebutja l'accés.

4

Error coherent

Codi HTTP adequat (401/403) i missatge d'error clar i consistent.

5

Documentació de la credencial

Explicació de com el client ha d'enviar la credencial a cada petició.

Errors habituals



→ Copiar el login de R2 sense adaptar-lo

El login usa sessions o cookies. Una API REST ha d'usar tokens o API keys, sense estat al servidor.

→ Oblidar el cas denegat

Presentar només el cas correcte és una evidència incompleta. Cal demostrar els dos escenaris.

→ Retornar codi HTTP 200 en l'error

Un accés denegat ha de retornar **401 Unauthorized** o **403 Forbidden**, mai un 200 amb missatge d'error dins.

→ No documentar l'ús de la credencial

Sense documentació, no queda clar com el client ha de fer les peticions. Cal especificar capçalera, format i exemple.

Checklist final

Abans d'entregar, verifica que tens tot això:



Mecanisme

Hi ha un mecanisme de control d'accés implementat i actiu a l'API.



Cas OK

Demostres una petició autoritzada amb resposta correcta.



Cas KO

Demostres una petició denegada amb codi HTTP adequat.



Error coherent

El missatge d'error és clar, consistent i amb el codi HTTP correcte.



Documentació

Expliques com el client ha d'enviar la credencial (capçalera, format, exemple).

Pregunta de tancament

En quin punt del flux es comprova l'accés i **què passa si falla?**

Prepara la resposta: identifica on s'intercepta la petició (middleware, filtre, inici del controlador), quin codi HTTP es retorna, quin missatge rep el client, i si el flux s'atura o continua.

- ❗ Aquesta pregunta forma part de l'avaluació oral del microrepte. Una resposta clara i precisa demostra que entens el disseny del control d'accés, no només que el codi funciona.

